НЕГОСУДАРСТВЕННОЕ ОБРАЗОВАТЕЛЬНОЕ ЧАСТНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
«МОСКОВСКИЙ ФИНАНСОВО-ПРОМЫШЛЕННЫЙ УНИВЕРСИТЕТ «СИНЕРГИЯ»»

Факультет Информационных технологий

Направление подготовки:	09.03.02 Информационные системы и технологии	**Кафедра**	ИИиАД
(код, наименование)		*(аббревиатура)*	

Профиль: Разработка, сопровождение и обеспечение безопасности информационных систем

РЕШЕНИЕ КЕЙСА № 4

по дисциплине «Искусственный интеллект, большие данные и этика»

на тему **Deepfake и биометрия: защита личности в сервисах онлайн-проверки**

Обучающийся ***Шатов Илья Андреевич***

(Фамилия Имя Отчество) *(подпись)*

Группа ***ДМЭ-101цэии***

Преподаватель

(Фамилия Имя Отчество) *(подпись)*

МОСКВА 2026 г.

СОДЕРЖАНИЕ

ВВЕДЕНИЕ.....3
1 Биометрические данные как особая категория: риски и требования к согласию.....4
2 Dual-use генеративных моделей: обязательность и формы ограничений.....6
3 Чек-лист Privacy by Design для сервиса проверки личности.....8
ВЫВОДЫ.....10
СПИСОК ИСТОЧНИКОВ.....11

ВВЕДЕНИЕ

Онлайн-идентификация по лицу и голосу стала обыденной: сервисы проверяют пользователя по селфи и голосовому образцу. Одновременно генеративные технологии делают доступным создание реалистичных подделок — deepfake-видео и клонов голоса — по одному образцу. Одна и та же технология одновременно защищает личность и угрожает ей.

Ситуация кейса: сервис онлайн-идентификации хранит «сырые» фотографии лиц и образцы голоса пользователей; предлагается внедрить генеративную модель синтеза лиц «для улучшения качества» фотографий; конкуренты уже применяют генеративные модели для обхода процедур идентификации. Изображение лица и запись голоса — биометрические персональные данные.

Цель работы — определить особые требования к обработке биометрии, оценить обязанность ограничивать dual-use генеративные модели и разработать чек-лист Privacy by Design для сервиса проверки личности. Задачи соответствуют пунктам задания и раскрыты в разделах 1–3.

1 Биометрические данные как особая категория: риски и требования к согласию

Условие. Объясните особый статус биометрических данных: необратимость компрометации, бессрочность риска, требования к согласию субъекта. Оцените правомерность хранения «сырых» изображений и обучения на них без отдельного согласия.

Биометрические данные отличаются от паролей фундаментально: компрометация необратима. Пароль можно сменить, карту перевыпустить — лицо и голос человеку заменить нельзя. Отсюда бессрочность риска: утечка базы селфи сохраняет актуальность на всю жизнь субъектов, а в связке с генеративными моделями один образец достаточен для создания убедительной подделки — видео с движениями губ или голосового клона. Именно поэтому закон относит биометрию к особым категориям: статья 11 закона № 152-ФЗ требует письменного согласия на обработку биометрических персональных данных; статья 9 GDPR включает биометрические данные, используемые для уникальной идентификации, в специальные категории с запретом обработки по умолчанию.

Из особого статуса следуют требования к согласию: оно должно быть явным (отдельное действие субъекта, а не «галочка в договоре»), информированным (субъект знает, что именно обрабатывается, зачем, как долго и с какими рисками), пошаговым (отдельные согласия на проверку, хранение и на использование в обучении — это разные обработки) и отзывным (право отозвать согласие в любой момент с удалением данных). Согласие «на всё сразу» юридически и этически несостоятельно: оно не информировано по определению.

Хранение «сырых» изображений и обучение на них без отдельного согласия неправомерно и неоправданно пропорционально. Для проверки подлинности пользователю достаточно хранить сравниваемый шаблон (вектор признаков/эмбеддинг), а не саму фотографию: принцип минимизации

данных прямо требует обрабатывать столько данных, сколько необходимо для цели. Обучение на биометрии клиентов — отдельная обработка с иной целью, требующая собственного явного согласия; этически она оправдана лишь крайне редко, а безопасной альтернативой служат синтетические данные и эмбеддинги вместо сырых изображений. Требования к защите биометрической информации стандартизованы ISO/IEC 24745: возобновляемость шаблонов, необратимость преобразования и неотслеживаемость связей между приложениями.

Вывод: биометрия — необратимая и бессрочно уязвимая идентичность; закон (ст. 11 № 152-ФЗ, ст. 9 GDPR) требует явного, информированного, пошагового и отзывного согласия. Хранение «сырых» изображений и обучение на них без отдельного согласия неоправданны: минимизация требует шаблонов вместо изображений и синтетики вместо клиентских данных в обучении.

2 Dual-use генеративных моделей: обязательность и формы ограничений

Условие. Обсудите проблему dual-use генеративных технологий: обязаны ли разработчики ограничивать применение? Какие меры разумны (watermarking, происхождение контента C2PA, лимиты и идентификация клиентов API, запрет клонирования голоса без согласия) и что означает доступность open-source моделей для обороны?

Генеративные модели — классический dual-use: одна и та же способность синтезировать лицо и голос даёт и полезные продукты (доступность, производство контента), и инструменты мошенничества и обхода идентификации. Ответ на вопрос «обязаны ли?» двусоставной. Юридически обязанность формируется уже сейчас: Регламент (ЕС) 2024/1689 вводит обязанности прозрачности для систем, генерирующих синтетический контент, — маркировка машинно-сгенерированных данных в машиночитаемом виде. Этически обязанность следует из общего принципа ответственности за предвидимые последствия выпуска технологии: производитель, знающий о злоупотреблениях и способный снизить их вероятность без разрушения полезности, должен это делать. «Технология нейтральна» не освобождает от проектных решений, влияющих на масштаб вреда.

Разумные ограничения перечислены в таблице 1: они снижают вероятность злоупотребления, не отменяя легитимных применений. Важно признать предел этих мер: они повышают стоимость злоупотребления, но не делают его невозможным, поскольку распространение моделей с открытыми весами выводит генерацию из-под контроля провайдеров. Поэтому стратегия «только ограничения на выпуске» недостаточна: необходимо усиливать оборону на стороне приёмников — детекторы синтетики, liveness-проверки с активными вызовами, мультимодальное подтверждение, обмен сигнатурами

известных подделок. Логика двойного контура: у истока — маркировка и контроль доступа, у приёмника — проверка подлинности и живости.

Таблица 1 — Меры ограничения злоупотребления генеративными моделями

Мера	Уровень	Эффект и предел
Watermarking (невидимая маркировка)	Контент	Машиночитаемый признак синтетики; предел — удаление повторной обработкой
Происхождение контента (C2PA)	Контент	Криптографическая цепочка создания файла; усиливается инфраструктурой приёмников
Лимиты и KYC на API	Доступ	Идентификация клиентов, квоты, мониторинг паттернов злоупотребления
Запрет клонирования голоса без согласия	Доступ	Верификация прав на голос-источник; контрактный и технический запрет
Детекторы синтетики, liveness	Оборона	Работает при открытых весах; требует постоянного обновления (гонка вооружений)

Вывод: ограничения обязательны: юридически — прозрачность синтетического контента по Регламенту (ЕС) 2024/1689, этически — ответственность за предвидимые злоупотребления (таблица 1). Открытые веса снижают контролируемость на выпуске, поэтому стратегия дополняется обороной у приёмников: детекторы, liveness и мультимодальность.

3 Чек-лист Privacy by Design для сервиса проверки личности

Условие. Разработайте чек-лист Privacy by Design для сервиса проверки личности по лицу/голосу: минимизация данных, хранение шаблонов вместо изображений, cancellable biometrics, шифрование, on-device обработка, поэтапное согласие с правом на отзыв, liveness/anti-spoofing, аудит-логи, план реагирования на утечки.

Privacy by Design означает встраивание защиты в архитектуру сервиса, а не добавление её поверх готового продукта. Чек-лист (таблица 2) построен по жизненному циклу данных: сбор, преобразование, хранение, проверка, эксплуатация, инциденты. Каждая строка проверяема и относится к конкретному риску кейса: хранение шаблонов вместо «сырых» селфи снижает цену утечки; cancellable biometrics делают скомпрометированный шаблон «перевыпускаемым»; on-device обработка сокращает объём данных, покидающих устройство пользователя.

Таблица 2 — Чек-лист Privacy by Design сервиса проверки личности

№	Требование	Смысл
1	Минимизация данных	Собирать только данные, необходимые для проверки; без «на всякий случай»
2	Шаблоны вместо изображений	Хранить необратимые эмбеддинги; сырые кадры удаляются сразу после проверки
3	Cancellable biometrics	Трансформация шаблона с возобновляемым ключом: утечка «перевыпускается» сменой ключа
4	Шифрование	Шаблоны и логи шифруются в покое и в передаче; ключи — в HSM/менеджере секретов
5	On-device обработка	Извлечение признаков на устройстве пользователя, где возможно; на сервер — только шаблон
6	Поэтапное согласие с отзывом	Отдельные явные согласия на проверку, хранение, обучение; отзыв в один клик с удалением

7	Liveness / anti-spoofing	Активные вызовы, мультимодальность, детекторы deepfake на входе проверки
8	Аудит-логи	Журнал доступов, проверок и экспортов; неизменяемость; периодическая выборочная проверка
9	Пентест на deepfake	Регулярные попытки обхода синтетикой; red team по всем каналам
10	План реагирования на утечки	Роли, уведомление субъектов и регулятора, ротация ключей шаблонов, ретроспектива

Чек-лист в таблице 2 закрывает полный цикл: сбор и преобразование (строки 1–3, 5) устраняют саму возможность утечки «сырых» лиц; защита хранения (строка 4) снижает цену прорыва; согласия (строка 6) делают обработку правомерной по ст. 11 № 152-ФЗ и ст. 9 GDPR; эксплуатация (строки 7–9) противостоит deepfake-обходу; инцидентная готовность (строка 10) определяет действия, когда иные меры оказались недостаточными. Внедрение проверяется внутренним аудитом и оценкой воздействия на защиту данных.

Вывод: чек-лист Privacy by Design (таблица 2) переводит требования разделов 1–2 в архитектуру сервиса: минимизация, шаблоны вместо изображений, возобновляемые шаблоны, шифрование, on-device обработка, поэтапное отзывное согласие, liveness-защита, аудит, пентест на deepfake и план реагирования.

ВЫВОДЫ

В пункте (a) показано: биометрия отличается необратимостью компрометации и бессрочностью риска, поэтому ст. 11 закона № 152-ФЗ и ст. 9 GDPR требуют явного, информированного, пошагового и отзывного согласия; хранение «сырых» изображений и обучение на них без отдельного согласия неправомерны — минимизация достигается шаблонами и синтетическими данными.

В пункте (b) обоснована обязательность ограничений dual-use: watermarking, происхождение контента по C2PA, лимиты и KYC на API, запрет клонирования голоса без согласия (таблица 1); открытые веса снижают контролируемость выпуска, поэтому стратегия дополняется обороной у приёмников — детекторами, liveness и мультимодальностью.

В пункте (c) разработан чек-лист Privacy by Design (таблица 2): минимизация данных; хранение шаблонов вместо изображений; cancellable biometrics; шифрование; on-device обработка; поэтапное согласие с отзывом; liveness/anti-spoofing; аудит-логи; пентест на deepfake; план реагирования на утечки.

Общий вывод кейса: биометрический сервис несёт пожизненный риск для своих субъектов, поэтому стандарт проектирования — «утечка шаблона не равна утечке личности»: необратимые и возобновляемые шаблоны, минимальный сбор, прозрачные согласия и постоянная оборона от синтетических подделок.

СПИСОК ИСТОЧНИКОВ

1. Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных» (ст. 11 — биометрические персональные данные) // СПС «КонсультантПлюс». — Текст : электронный.
2. Федеральный закон от 29.12.2022 № 572-ФЗ «Об осуществлении идентификации и (или) аутентификации физических лиц с использованием биометрических персональных данных, о внесении изменений в отдельные законодательные акты Российской Федерации» // СПС «КонсультантПлюс». — Текст : электронный.
3. Регламент (ЕС) 2016/679 Европейского парламента и Совета от 27 апреля 2016 г. (General Data Protection Regulation, ст. 9) // EUR-Lex : [сайт]. — URL: https://eur-lex.europa.eu/eli/reg/2016/679/oj (дата обращения: 27.10.2026). — Текст : электронный.
4. ISO/IEC 24745:2022. Information security, cybersecurity and privacy protection — Biometric information protection. — Geneva : ISO, 2022.
5. C2PA Technical Specification / Coalition for Content Provenance and Authenticity (C2PA) : [сайт]. — URL: https://c2pa.org/specifications/ (дата обращения: 27.10.2026). — Текст : электронный.
6. NIST AI Risk Management Framework (AI RMF 1.0) / National Institute of Standards and Technology. — Gaithersburg, 2023. — URL: https://doi.org/10.6028/NIST.AI.100-1 (дата обращения: 27.10.2026).